機密等級：□一般■限閱□密□機密

全一電子股份有限公司
JEBSEE ELECTRONICS CO.，LTD

資訊安全風險評鑑與管理程序

Information Asset Risk Management Procedure

文件編號：IS-V2-04

Doc.No.：IS-V2-04

制訂部門：情資安全部　審　核：吳仲銘　制　作：郭銘儒

文件版次：1.1　修訂日期：2025/05/09　制訂日期：2024/6/17

相關部門勾選	V	V	V	V	V	V	V	V	V	V	V	V	V	V	V	V	V	V	V	V	V	V	V	V
部門名稱	營運管理處	業務部/市場行銷部	專案管理部	產品設計一部	產品設計二部	技術部	資料課	數位整合部	智慧賦能部	情資安全部	永續發展部	財務部	職安部	管理部	人資部	製造部	SMT	成型部	生產管理部	資材部	進出口課	工程部	品質保證部

表格編號：SP1-Q2-01-01 Rev1.1

JEBSEE	全一電子股份有限公司 JEBSEE ELECTRONICS CO.,LTD	文件編號	IS-V2-04
文件類別	文 件 變 更 紀 錄 表	制訂部門	情資安全部
文件名稱	資訊安全風險評鑑與管理程序 Information Asset Risk Management Procedure	文件版次	1.1

版次	變更摘要	修訂日期
1.0	資訊安全執行組初版發行，由召集人核准	6/17 ’24
1.1	增修威脅暨弱點評估、風險與機會重新評估，新增表單 IS-V2-04-03 威脅弱點評估表、IS-V2-04-04 風險與機會評鑑報告	05/09 ’25

目錄

目錄 1
1.0 目的： 2
2.0 範圍： 2
3.0 權責： 2
3.1 風險擁有者： 2
3.2 資訊安全執行組： 2
3.3 權責單位主管： 2
3.4 資訊流程權責單位： 2
4.0 相關參考文件： 2
4.1 IS-V2-03 資訊資產管理程序 2
4.2 IS-V2-15 資訊安全監督與量測管理程序 2
5.0 程序： 2
5.1 名詞定義 2
5.2 作業說明： 3
6.0 紀錄/表格： 6
6.1《風險改善與機會實作計畫表》表格編號：IS-V2-04-01 6
6.2《適用性聲明》表格編號：IS-V2-04-02 6
6.3《威脅弱點評估表》表格編號：IS-V2-04-03 6
6.4《風險與機會評鑑報告》表格編號：IS-V2-04-04 6
附件：資訊資產評估項目對應表 7

1.0 目的：

為建立全一電子股份有限公司（以下簡稱本公司）資訊安全管理制度（以下簡稱 ISMS）風險評鑑與管理規範，提供本公司資訊流程之權責單位、保管單位，以及使用單位，共同遵行之風險評鑑標準，有效執行風險控管，預防資訊安全事件之威脅。

2.0 範圍：

本公司資訊流程之風險與機會管理。

3.0 權責：

3.1 風險擁有者：

3.1.1 負責核定可接受風險值、風險評鑑結果、風險改善計畫、控制措施、機會評鑑結果、機會實作計畫。

3.2 資訊安全執行組：

3.2.1 負責複核相關資訊流程風險評鑑結果，並針對風險值超過可接受風險值之資訊流程，採取適當之控管措施，及產出「IS-V2-04-01 風險改善與機會實作計畫表」。

3.3 權責單位主管：

3.3.1 負責所屬單位業務範圍之風險評鑑結果審核作業。

3.4 資訊流程權責單位：

3.4.1 負責執行資訊流程之威脅與弱點評估、風險值計算等程序項目。

4.0 相關參考文件：

4.1 IS-V2-03 資訊資產管理程序

4.2 IS-V2-15 資訊安全監督與量測管理程序

5.0 程序：

5.1 名詞定義

5.1.1 機密性(Confidentiality)

5.1.1.1 確保僅授權人員可存取資訊。

5.1.2 完整性(Integrity)

5.1.2.1 確保資訊與處理方法的正確性與完整性。

5.1.3 可用性(Availability)

5.1.3.1 確保經授權的使用者在需要時可以取得資訊及相關資產。

5.1.4 可接受風險值

5.1.4.1 各類資訊流程之最低風險容忍度。

5.1.5 殘餘風險(Residual Risk)

5.1.5.1 在採用相關控制措施之後剩餘的風險。

5.1.6 威脅(Threat)

5.1.6.1 可能對系統或本公司造成傷害之意外事件。

5.1.7 弱點(Vulnerability)

5.1.7.1 因資訊資產本身狀況或所處環境之下，可能受到威脅利用而造成資產受到損害之因子。

5.1.8 風險(Risk)

5.1.8.1 可能對本公司的資訊流程發生損失或傷害的潛在威脅，通常利用弱點所產生之影響及發生可能性來衡量。

5.1.9 機會(Opportunities)

5.1.9.1 除了因應風險改善之計畫外，其他可增進本公司資訊安全的任何作為。

5.1.10 風險擁有者(Risk Owner)

5.1.10.1 本公司內針對各項資訊流程風險管理具備核准與確認者。

5.1.10.2 本公司風險擁有者為單位主管。

5.2 作業說明：

5.2.1 資訊資產之鑑別應依據本公司「IS-V2-03 資訊資產管理程序」進行鑑別及分類。

5.2.2 本公司風險評鑑流程為：

5.2.2.1 詳細風險評鑑

5.2.2.1.1 符合下列規範之資訊系統、服務，應進行威脅弱點評估：

5.2.2.1.1.1 屬於本公司 ISMS 施作範圍內之機房重要基礎設施、服務、資訊流程。

5.2.2.1.2 威脅暨弱點評估

5.2.2.1.2.1 將應進行威脅弱點評估之資訊系統、服務，可能面臨之事件(威脅-弱點)分為六類，包括：

5.2.2.1.2.1.1 人為：包含因人員有意或無意行為、人力資源管理不當所產生之風險。

5.2.2.1.2.1.2 文件/資料：包含資料、文件之建立、維護、控管、傳遞之不當所產生之風險。

5.2.2.1.2.1.3 軟體：包含系統設計、維護、操作之不當所產生之風險。

5.2.2.1.2.1.4 硬體：包含所有硬體設施之失效、損毀等可能風險。

5.2.2.1.2.1.5 通訊：包含資料、影像、聲音傳輸媒介失效等所可能產生之風險。

5.2.2.1.2.1.6 環境：包含天災、供水、用電、空調等，整體資訊環境，可能發生之風險。

5.2.2.1.2.2 評估各類事件，並將各資產面臨之主要事件登載於「威脅弱點評估表」表格編號：IS-V2-04-03。

5.2.2.1.2.3 資訊資產價值之數值若為 7（含 7）以上，必須進行威脅弱點評估，資訊資產價值評分方式參閱「IS-V2-03 資訊資產管理程序」。

5.2.2.1.2.4 資訊資產之機密性、可用性及完整性之數值，若其中一項數值為 4 者，必須進行威脅弱點評估。

5.2.2.1.2.5 屬於本公司業務流程內之重要基礎設施、服務。

5.2.2.1.3 事件發生機率及衝擊的評估

5.2.2.1.3.1 事件發生機率及衝擊的評估可依以下步驟進行：

5.2.2.1.3.1.1 依各資訊資產之分類，查照「資訊資產評估項目對應表(附件)」進行選擇所需評估的事件(威脅-弱點)類別。

5.2.2.1.3.1.2 依以下之標準評估各事件發生機率及衝擊程度：

5.2.2.1.3.1.2.1 事件發生機率的評估：事件(威脅-弱點)發生機率值可參考下表得出。

5.2.2.1.3.1.2.2 事件發生機率/等級對應表

可能性	評估標準	數值
無或微	■ 無發生可能或不適用之情形。 ■ 對於可預期之資訊安全威脅缺乏動機或能力不足以利用脆弱點造成資安事件。 ■ 資訊安全事件因控制措施執行得當，有效降低脆弱點被利用，幾乎不可能發生。 ■ 三年發生之次數約 1 次或不發生，或屬於天災無法預估其發生可能性。	1
低	■ 很少發生。 ■ 對於可預期之資訊安全威脅具有動機但能力不足以利用脆弱點造成資安事件。 ■ 資訊安全事件因控制措施執行得當，有效降低脆弱點被利用，致使威脅發生之可能性極低。 ■ 一年發生之次數約 1 次，或三年 1 次以上 3 次以下。	2
中	■ 偶爾發生。 ■ 對於可預期之資訊安全威脅具有動機且有能力利用脆弱點造成資安事件。 ■ 已採行部份資訊安全措施，脆弱點仍未被有效降低或減少，致使威脅發生之機率略高。 ■ 一季發生之次數約 1 次，或一年 1 次以上 4 次以下。	3
高	■ 經常發生。 ■ 對於可預期之資訊安全威脅具有動機且有能力利用脆弱點造成資安事件。 ■ 未實行資訊安全措施或安全措施無效，脆弱點仍未被有效降低或減少，致使威脅發生機率偏高。 ■ 一個月發生次數 1 次以上，或一季發生 2 次。	4

5.2.2.1.3.1.2.3 事件衝擊程度的評估：主要針對各項威脅利用弱點而產生事件，判斷該事件發生對於資訊資產價值的衝擊程度，可由機密性、完整性與可用性三方面綜合考量。

5.2.2.1.3.1.2.4 衝擊評估標準/等級對應表

衝擊性	衝擊評估標準	數值
無或微	■ 資訊安全事件發生時，對資產並不會造成損失或僅造成極小的損失。 ■ 對於業務執行沒有影響。 ■ 可以立即完成復原。 ■ 若持續發生且次數頻繁，對業務執行可能帶來潛在風險。	1
低	■ 資訊安全事件發生時，對資產會造成輕微的損失。 ■ 對於整體營運或業務執行影響不大。 ■ 造成的損害可能僅影響單一業務或系統。 ■ 損失僅影響個人或少數幾人。 ■ 可以由內部人員進行復原。 ■ 修復或進行復原的措施可以在很短時間(一天)內完成。	2

衝擊性	衝擊評估標準	數值
中	■ 資產機密等級誤判或機密性維護機制失能時，對資產本身或相關資產造成間接或輕微的影響。 ■ 資訊安全事件發生時，對資產會造成較大的損失。 ■ 對於本公司數項業務營運或執行造成停頓。 ■ 造成的損害可能影響多種業務、數個系統、多個部門或合作夥伴。 ■ 復原的措施必須由專業人員才能進行。 ■ 復原可能要一天到三天才能完成。 ■ 可能造成人員遭遇危險或受到傷害。	3
高	■ 資產機密等級誤判或機密性維護機制失能時，對資產本身或相關資產造成直接且嚴重的影響。 ■ 資訊安全事件發生時，對資產會造成嚴重的損失。 ■ 對於本公司多項業務營運或執行造成停頓。 ■ 造成的損害可能影響本公司或利益相關者。 ■ 復原的措施僅能由外部特定專業人員才能進行或修復人員不易取得。 ■ 復原無法於三天到一週內完成。 ■ 可能造成人員傷亡。	4

5.2.2.1.4 風險值的計算

5.2.2.1.4.1 資訊資產風險值=資訊資產價值 X 事件發生可能性 X 事件衝擊性。

5.2.2.1.4.2 資訊流程綜合風險值=MAX（組成資訊流程的資訊資產風險值）。

5.2.2.2 確認風險評估結果

5.2.2.2.1 彙整相關資訊流程綜合風險值，產出「風險與機會評鑑報告」表格編號：IS-V2-04-04，供資訊安全委員會作風險管理之依據。

5.2.2.3 風險管理

5.2.2.3.1 可接受風險值的決定

5.2.2.3.1.1 本公司相關資訊資產之可接受風險值，需經風險擁有者核准。

5.2.2.3.1.2 可接受風險值得考量本公司環境及作業之安全需求作適當調整。

5.2.2.3.2 選擇控制措施

5.2.2.3.2.1 評估資訊流程之最終風險值後，風險分析結果應陳報風險擁有者。若風險值超出可接受風險值之資訊資產，應選擇適當之控管措施。產出「IS-V2-04-01 風險改善與機會實作計畫表」，說明風險控管措施之執行辦法。

5.2.2.3.2.2 「IS-V2-04-01 風險改善與機會實作計畫表」應由風險擁有者審核，並列入追蹤管理程序。

5.2.2.3.3 風險改善狀況的後續追蹤

5.2.2.3.3.1 對風險評鑑後所提出之風險改善計畫應彙整控管，持續追蹤至完成改善為止。

5.2.2.3.4 產出「IS-V2-04-02 適用性聲明」

5.2.2.3.4.1 依據風險評鑑結果所選擇之控制措施，對照 ISO/IEC 27001:2022 版本附錄 A，產出「IS-V2-04-02 適用性聲明」。

5.2.2.3.4.2 若所選擇之控制措施不在 ISO/IEC 27001:2022 版本附錄 A 中，則仍須於「IS-

V2-04-02 適用性聲明」中進行說明。

5.2.2.4 監督、量測、分析及評估

5.2.2.4.1 針對所選擇之各項控制措施，挑選必要之項目進行監督與量測，詳細作業程序請參閱本公司「IS-V2-15 資訊安全監督與量測管理程序」。

5.2.2.5 機會評鑑與實作

5.2.2.5.1 機會評鑑：應參照組織全景分析中內、外部議題以及關注者對於本公司資訊安全要求與期望，評估列入「IS-V2-04-01 風險改善與機會實作計畫表」可增進本公司資訊安全之各項機會。

5.2.2.5.2 資訊安全執行小組應針對所識別之各項機會進行可行性評估，並將評估結果寫入「風險與機會評鑑報告」表格編號：IS-V2-04-04 中。

5.2.2.6 資訊安全執行小組應針對已識別之機會進行實作程序討論，並將實作內容填入「IS-V2-04-01 風險改善與機會實作計畫表」，陳報風險擁有者核准。

5.2.2.7 複核

5.2.2.7.1 風險與機會重新評估

5.2.2.7.1.1 每年應至少執行 1 次風險與機會評鑑。

5.2.2.7.1.2 當範圍內有以下的狀況發生之時，則實施不定期的複核，以更新及確保資訊流程風險評估的正確性及完整性：

5.2.2.7.1.2.1 有新增、變更或移除資訊資產，且該資訊資產價值超過 7(含 7)以上。

5.2.2.7.1.2.2 作業環境改變。

5.2.2.7.1.2.3 組織之生產、營運有重大變動。

5.2.2.7.1.2.4 發生重大資安事件時。

6.0 紀錄/表格：

6.1《風險改善與機會實作計畫表》表格編號：IS-V2-04-01

6.2《適用性聲明》表格編號：IS-V2-04-02

6.3《威脅弱點評估表》表格編號：IS-V2-04-03

6.4《風險與機會評鑑報告》表格編號：IS-V2-04-04

附件：資訊資產評估項目對應表

風險種類 / 資產類別	環境風險	資料、文件風險	軟體風險	硬體風險	通訊風險	人為風險
硬體	✓			✓		✓
軟體			✓	✓		✓
資料		✓	✓	✓		✓
文件		✓				✓
人員						✓
通訊				✓	✓	✓
環境	✓					✓